

SIMATS ENGINEERING

ASSESSMENT TOOL 1 — Report Analysis: Model Answers

Course Name: Ethical Hacking

Name: Mounnila S P

Course Code: ITA1406

Reg no:192511188

Course Outcome: CO2 — Footprinting Tools, DNS Zone Transfers, Social Engineering Attacks and Countermeasures

Q1. Nmap Scan Report Analysis — 192.168.1.10

Interpretation of the Scan Report

The Nmap scan on 192.168.1.10 identified three open ports along with OS and service version banners: HTTP (80), SSH (22), and MySQL (3306). Each open service, combined with its version information, expands the target's attack surface and gives an attacker a starting point for exploitation.

Security Risks by Service

- HTTP (Port 80): Unencrypted traffic exposes data in transit; the web application may carry vulnerabilities such as SQL Injection, Cross-Site Scripting (XSS), outdated CMS plugins, directory listing, and information disclosure through default error pages or banners.
- SSH (Port 22): Exposed to brute-force and credential-stuffing attacks; outdated OpenSSH versions may carry known CVEs; weak or reused passwords allow unauthorized remote shell access.
- MySQL (Port 3306): Direct exposure of a database service to the network allows brute-force login attempts, exploitation of unpatched CVEs, and potential remote code execution or data exfiltration if authentication is weak or default credentials remain in use.
- OS/Service Fingerprinting: Precise version banners let an attacker cross-reference public vulnerability databases (CVE/Exploit-DB) to identify a ready-made exploit for that exact version, dramatically reducing reconnaissance effort.

How an Attacker Could Exploit These Findings

An attacker would first match the fingerprinted service versions against known CVEs. They could run automated brute-force tools (e.g., Hydra) against SSH and MySQL using leaked or common credential lists, attempt SQL Injection or known CMS exploits against the web application on port 80, and — if a web shell or SQLi foothold is gained — pivot to the MySQL service to exfiltrate or manipulate data. Chaining a web application compromise with database access is a common attack path when all three services are exposed together.

Recommended Security Measures

- Restrict MySQL (3306) from direct external exposure; bind it to localhost or an internal network, and allow access only via VPN or SSH tunnel.
- Apply security patches promptly and disable version banners so exact software versions are not disclosed.
- Enforce SSH key-based authentication, disable root login, change the default port, and deploy brute-force protection (e.g., fail2ban).
- Use strong password policies and multi-factor authentication for all administrative access.
- Deploy HTTPS/TLS on the web service and place a Web Application Firewall (WAF) in front of it.
- Perform regular vulnerability scanning and network segmentation to isolate critical services.
- Apply least-privilege database accounts and encrypt data in transit and at rest.

Q2. Phishing Awareness Campaign (GoPhish) — ABC Technologies Pvt. Ltd.

Interpretation of the Campaign Results

Out of the employees targeted, 40% clicked the phishing link, 20% entered login credentials, and several downloaded a malicious attachment. These figures indicate a significant gap between employee awareness and the sophistication of the simulated attack.

Security Weaknesses Demonstrated

- Low ability to recognize phishing indicators such as urgency, spoofed sender addresses, and mismatched links.
- No habit of verifying a request through a secondary/official channel before acting.
- Willingness to enter credentials on an unverified page, showing a lack of 'stop and check' behaviour.
- Opening unsolicited attachments without scanning or suspicion, indicating no security-first mindset.
- Absence of a reporting culture — no evidence employees flagged the email to IT/security before interacting with it.

Recommended User Awareness Programs

- Conduct recurring (quarterly) simulated phishing exercises with escalating difficulty and immediate feedback ('teachable moment' landing pages).
- Run structured security-awareness training covering how to spot spoofed senders, suspicious URLs, and urgency-based social engineering.

- Gamify awareness with recognition for employees who report phishing rather than click it.

Recommended Email Security Controls

- Implement SPF, DKIM, and DMARC to reduce sender spoofing.
- Deploy attachment sandboxing/detonation and URL rewriting or link-scanning at the email gateway.
- Use advanced spam/phishing filters and flag external-origin emails clearly.

Recommended Organizational Policies

- Mandatory, blame-free reporting of suspicious emails through a one-click 'Report Phishing' button.
- Least-privilege access so a single compromised account has limited blast radius.
- Endpoint protection/EDR to detect and contain malicious attachments that are opened despite training.
- Incident response procedure specifically for credential-compromise scenarios (forced password reset, session invalidation, MFA enforcement).

Q3. DNS Zone Transfer (AXFR) Assessment

Security Implications of the Exposed Information

A successful AXFR zone transfer hands an attacker the organization's complete DNS zone file — internal hostnames, mail server (MX) records, subdomains, and other DNS entries — effectively providing a map of the internal network without any need for brute-force enumeration.

How Attackers Could Exploit These Findings

- Build a full inventory of internal and external hosts, including test/staging/development servers that are often less secured.
- Identify mail servers to craft convincing spear-phishing infrastructure or targeted email attacks.
- Use discovered hostnames and naming conventions to guide further reconnaissance, vulnerability scanning, and social engineering pretexts.

Best Practices to Secure DNS Infrastructure

- Restrict zone transfers (AXFR) to explicitly authorized secondary name-server IP addresses only.
- Use TSIG (Transaction Signature) authentication between primary and secondary DNS servers.

- Disable AXFR entirely on public-facing authoritative DNS servers where not required.
- Implement split-horizon DNS to separate internal-only records from publicly resolvable records.
- Regularly audit DNS server configuration and monitor for unauthorized transfer attempts.